

Full System Audit & Architecture Report

Comprehensive code quality, security vulnerability, functional integrity, and scalability assessment across the entire autonomous job hunting engine.

AUDIT SCOPE	AUDIT DATE	TARGET STACK	SYSTEM READINESS
Full Monorepo (Backend + UI)	August 30, 2026	FastAPI • SQLite WAL • Playwright	Action Required (5 Blockers)

5 CRITICAL BLOCKERS	5 HIGH SEVERITY GAPS	8 MEDIUM ISSUES	9 OPTIMIZATIONS
------------------------	-------------------------	--------------------	--------------------

Executive Verdict: JobCopilot possesses a high-quality local-first foundation (SQLite WAL, Argon2id/AES-256-GCM, and Playwright stealth contexts). However, several critical runtime bugs (non-existent enum references in bot execution, always-True deduplication fallback, and wildcard CORS credentials) must be addressed before running live autonomous job applications.

Audit Overview by Architectural Layer

LAYER / COMPONENT	HEALTH	KEY RISK AREA	AUDIT SUMMARY
Autonomous Bot Engine app/bot/*	CRITICAL (45/100)	Runtime Enum & State Crashes	runner.py assigns invalid enum APPLIED and non-existent attribute submission_mode.
0-Day Discovery & Deduplication app/discovery/*	CRITICAL (55/100)	Logic Flaw in Deduplication	is_duplicate() returns True unconditionally when description is blank. Discovery flag locks on error.
Security & API Layer app/main.py, app/api/*	HIGH (62/100)	CORS & Path Traversal	Wildcard CORS with credentials breaks browser spec; unvalidated file path in encrypted backup restore.
Resume Parsing & Compilation app/core/resume_*	MEDIUM (70/100)	Hardcoded Project Heuristics	Resume parser uses static strings instead of dynamic section extraction; missing file size limits on upload.
Storage & Vector Vault app/core/database.py, vault.py	HIGH (72/100)	O(N) Full-Table Scans	Missing database indexes on status and slot_key; full deserialization scan on every Q&A lookup.
Frontend & Deployment frontend/*, docker-compose.yml	MEDIUM (75/100)	Docker Volume Path Mismatch	Compose mounts ./data to /app/backend/data while app writes to ~/.jobcopilot.

1. Critical Bugs (Immediate Action Required)

C-01 Runtime Crash: Missing `submission_mode` & Non-Existent `ApplicationStatus.APPLIED`

backend/app/bot/runner.py:130-140

In `AutonomousJobRunner.execute_application()`, the runner sets `job.status = ApplicationStatus.APPLIED` and `job.submission_mode = "DRY_RUN"`. In `models.py`, the status enum only defines `SUBMITTED`, not `APPLIED`. Furthermore, `JobListing` lacks a `submission_mode` field.

```
# backend/app/bot/runner.py (Broken lines 130-131) - job.status = ApplicationStatus.APPLIED # ❌ AttributeError: APPLIED does not exist - job.submission_mode = "DRY_RUN" # ❌ Not in JobListing Pydantic schema + job.status = ApplicationStatus.SUBMITTED + job.submission_mode = "DRY_RUN" # ✅ Add field to JobListing model
```

Direct Impact: Every single bot run crashes immediately upon completing form fill. Additionally, `AnalyticsEngine` metrics for `DRY_RUN/LIVE` counts always report 0.

C-02 Logic Flaw: Deduplication Utility `is_duplicate()` Always Returns `True`

backend/app/core/deduplicator.py:150

In `JobDeduplicator.is_duplicate()`, the final fallback statement unconditionally returns `True` if neither job has a description. Two completely different jobs from the same company will be marked as duplicates.

```
# backend/app/core/deduplicator.py (Broken line 150) - return True # ❌ Always flags any two non-empty titles at the same company as duplicate + return False # ✅ Default to False unless explicit similarity matches
```

Direct Impact: Any component calling `is_duplicate()` will discard genuine job listings from the same company (e.g. "Frontend Engineer" vs "Backend Engineer").

C-03 Security & Spec Violation: Insecure Wildcard CORS with Credentials

backend/app/main.py:21-27

`FastAPI` CORS middleware is configured with `allow_origins=["*"]` and `allow_credentials=True`. According to the W3C fetch specification, web browsers reject requests with credentials if wildcard origin is specified.

```
# backend/app/main.py - allow_origins=["*"], allow_credentials=True + allow_origins=["http://localhost:8000", "http://127.0.0.1:8000", "http://localhost:5173"], allow_credentials=True
```

Direct Impact: Cross-origin frontend clients fail with CORS policy errors in standards-compliant browsers. If exposed to network, enables CSRF cross-origin leakage.

C-04 Overfitting: Resume Parser Hardcodes Specific Candidate Projects

backend/app/core/resume_parser.py:208-243

`ResumeParser.extract_projects_and_experience()` contains hardcoded string searches for "skin lesion", "resnet", "qdrant" and assigns static company name "Engineering Innovation Labs". For any other candidate, the parser creates incorrect project objects.

Direct Impact: System fails to be a universal candidate platform; tailored resumes and outreach generated for general users will contain fabricated or mismatched projects.

C-05 Silent Drop: Bot Runner Generates Outreach Packages but Discards Them

backend/app/bot/runner.py:77-82

In `AutonomousJobRunner.execute_application()`, `OutreachGenerator.create_triple_threat_package()` is called, but its return value is discarded without being saved to SQLite or returned in the response dictionary.

Direct Impact: Generated Triple-Threat LinkedIn/Email drafts for applied jobs are completely lost.

2. High-Severity Resilience & Security Vulnerabilities

H-01

State Deadlock: `DiscoveryOrchestrator.is_running` Stuck on Unhandled Exception

backend/app/discovery/orchestrator.py:52-145

`self.is_running = True` is set at the start of discovery, but `self.is_running = False` is only reached at the end of the method without a `try ... finally` block. If any network timeout or database error occurs, `is_running` remains `True` permanently.

Remediation: Wrap the entire discovery execution inside `try: ... finally: self.is_running = False`.

H-02

Data Loss: Docker Compose Mount Path Does Not Match Core App Storage

docker-compose.yml:12

& app/core/config.py:10

`docker-compose.yml` mounts `./data:/app/backend/data`, but `config.py` hardcodes `APP_DIR = Path(os.path.expanduser("~/jobcopilot"))`. SQLite database, encryption keys, and tailored PDFs are written inside the container's root home directory, causing all user data to vanish when the container restarts.

```
# app/core/config.py + APP_DIR = Path(os.environ.get("JOBCOPILOT_DATA_DIR", os.path.expanduser("~/jobcopilot")))
```

H-03

Security Risk: Plaintext Master Key Fallback Without Restricted File Permissions

backend/app/core/credential_vault.py:58-65

When OS Keychain is unavailable (e.g. Linux servers, headless containers), the encryption master key is written to `~/jobcopilot/.master.key` in plaintext without setting POSIX permissions (`chmod 0600`). Any process running under the same user or shared volume can read the master key.

Remediation: Apply `os.chmod(fallback_file, 0o600)` immediately after file creation.

H-04

Security Risk: Arbitrary Path Traversal in Encrypted Backup Restore Endpoint

backend/app/api/endpoints.py:530-540

`POST /api/backup/restore` takes a raw string `backup_file_path` directly from user JSON without validating whether the resolved path resides within the designated `BACKUPS_DIR`.

Remediation: Enforce `resolved_path.is_relative_to(BACKUPS_DIR)` or accept only backup filenames instead of arbitrary paths.

H-05

Scalability Bottleneck: $O(N)$ In-Memory Table Scans on Knowledge Vault Lookups

backend/app/core/vector_vault.py:93-103, 159-185

Both `learn_answer()` and `query_answer()` execute `db.get_all_vault_entries()`, deserializing JSON embeddings for every single database row into Python memory to perform slot matching. As the vault scales, form-filling latency degrades significantly.

Remediation: Query SQLite directly by `slot_key` index for exact matches; restrict vector similarity scans to top candidate candidates.

3. Medium & Low Severity Findings

ID	SEVERITY	COMPONENT	DESCRIPTION & REMEDIATION
M-01	MEDIUM	backend/requirements.txt	playwright is missing from requirements. A standard <code>pip install -r requirements.txt</code> will fail to run the bot engine. Add <code>playwright>=1.40.0</code> .
M-02	MEDIUM	backend/app/core/backup.py	<code>restore_encrypted_backup()</code> exports outreach records during backup, but forgets to restore them during recovery. Restore routine should insert outreach entries.
M-03	MEDIUM	backend/app/api/endpoints.py	Resume upload lacks max file size limits and MIME-type validation. An oversized payload could cause memory exhaustion or disk filling.
M-04	MEDIUM	backend/app/main.py	WebSocket disconnect and message exceptions are caught with bare <code>except Exception: pass</code> without logging, obscuring bot streaming telemetry errors.
M-05	MEDIUM	frontend/js/app.js	Salary currency conversion uses hardcoded exchange rates (1 USD = 83.5 INR). Integrate a lightweight client-side FX fetch with fallback.
L-01	LOW	backend/app/core/database.py	Missing database index on <code>jobs(status)</code> , <code>jobs(priority_score)</code> , and <code>vault(slot_key)</code> . Add <code>CREATE INDEX IF NOT EXISTS</code> .
L-02	LOW	backend/app/core/deduplicator.py	SimHash shingles use MD5 hash function. Upgrade to SHA-256 for consistent cryptographic hygiene.
L-03	LOW	backend/app/api/endpoints.py	Zero rate-limiting on <code>/api/discovery/run</code> , leaving external ATS APIs vulnerable to IP throttling. Add request rate throttling.

4. Prioritized Remediation Roadmap

PHASE 1 Immediate Blockers (Hours 0 – 24)

- Fix `ApplicationStatus.APPLIED` → `SUBMITTED` in `runner.py`
- Add `submission_mode` field to `JobListing` in `models.py`
- Fix `deduplicator.py` to return `False` on fallback
- Lock down CORS allowed origins in `main.py`
- Add `playwright>=1.40.0` to `requirements.txt`

PHASE 2 Resilience & Docker Storage (Days 1 – 3)

- Align `APP_DIR` with `JOBCOPILOT_DATA_DIR` environment variable
- Wrap discovery orchestration with `try ... finally`
- Enforce `chmod 0600` on plaintext master key fallback
- Add path traversal boundary checks in backup restore endpoint
- Store and return outreach package in bot runner execution

PHASE 3 Generic NLP & Parser Hardening (Week 1)

- Replace hardcoded project extraction with generic section parser
- Add file size (10MB max) and MIME checks on resume uploads
- Create SQL indexes on `jobs(status)` and `vault(slot_key)`
- Include outreach records in backup restore routine

PHASE 4 Enterprise Scalability & Telemetry (Week 2+)

- Implement SQLite connection pooling / reuse per thread
- Add rate-limiting on discovery endpoints
- Add live exchange rate caching for multi-currency slider
- Add automated regression test suite covering all bot adapters

Deployment Recommendation: Complete Phase 1 and Phase 2 before running live automated application batches or deploying via Docker.